1. Клонирование репозитория 1
2. Установка Gitleaks и TruffleHog (macOS) 1
3. Сканирование с помощью Gitleaks 1
5. Вывод 2
6. Конфигурация GitLab-CI 2

1. Клонирование репозитория

```bash
# Клонировать репозиторий
git clone https://github.com/NetSPI/django.nV.git

# Перейти в папку проекта
cd django.nV
```

2. Установка Gitleaks и TruffleHog (macOS)

```bash
# Установить Gitleaks
brew install gitleaks
# Установить TruffleHog
brew install trufflehog
```

3. Сканирование с помощью Gitleaks

```bash
gitleaks detect --no-git -v --config gitleaks-orig.toml --report-format json --report-path gitleaks-report.json
```

* detect — базовая команда для сканирования репозитория

* --no-git - использовать поиск в текущем каталоге

* --config - файл с преднастроенной проверкой

* -v (verbose) — выводит найденные секреты в консоль

** --report-format - формат вывода отчёта*

** --report-path — сохраняет полный структурированный отчет в файл.*

```

4. Сканирование с помощью TruffleHog

TruffleHog по умолчанию не ищет такие простые пароли:

- Отсутствие характерных паттернов — TruffleHog ищет определённые форматы: AWS-ключи, JWT-токены, приватные ключи, строки подключения к БД и т.п.

- Низкая энтропия — слово password не выглядит как случайная строка (API-ключ, токен).

- Кастомные детекторы — можно научить TruffleHog искать любые шаблоны, но проще воспользоваться другими инструментами.

5. Вывод

Для поиска явных паролей в открытом виде (как в users.json) лучше использовать обычный grep или аналоги.

TruffleHog - предназначен для обнаружения высокоэнтропийных учётных данных (ключи API, токены, сертификаты).

Gitleaks — поддерживает кастомные правила и лучше работает с JSON.

6. Конфигурация GitLab-CI

В GitLab создать пустой репозиторий с названием django.nV

Перейти в оригинальный репозиторий на хостовой машине и добавить файл .gitlab-ci.yml

```plaintext

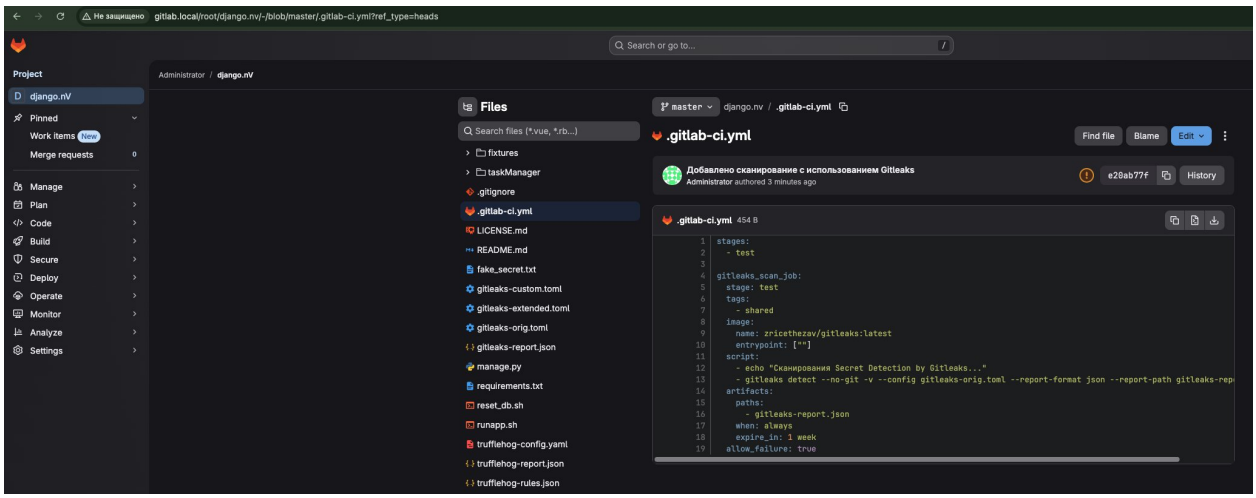
stages:

  - test
```
```

```
gitleaks_scan_job:
  stage: test
  tags:
    - shared
  image:
    name: zricethezav/gitleaks:latest
    entrypoint: [""]
  script:
    - echo "Сканирования Secret Detection by Gitleaks..."
    - gitleaks detect --no-git -v --config gitleaks-orig.toml --report-format json --report-path gitleaks-report.json
  artifacts:
    paths:
      - gitleaks-report.json
    when: always
    expire_in: 1 week
  allow_failure: true
```

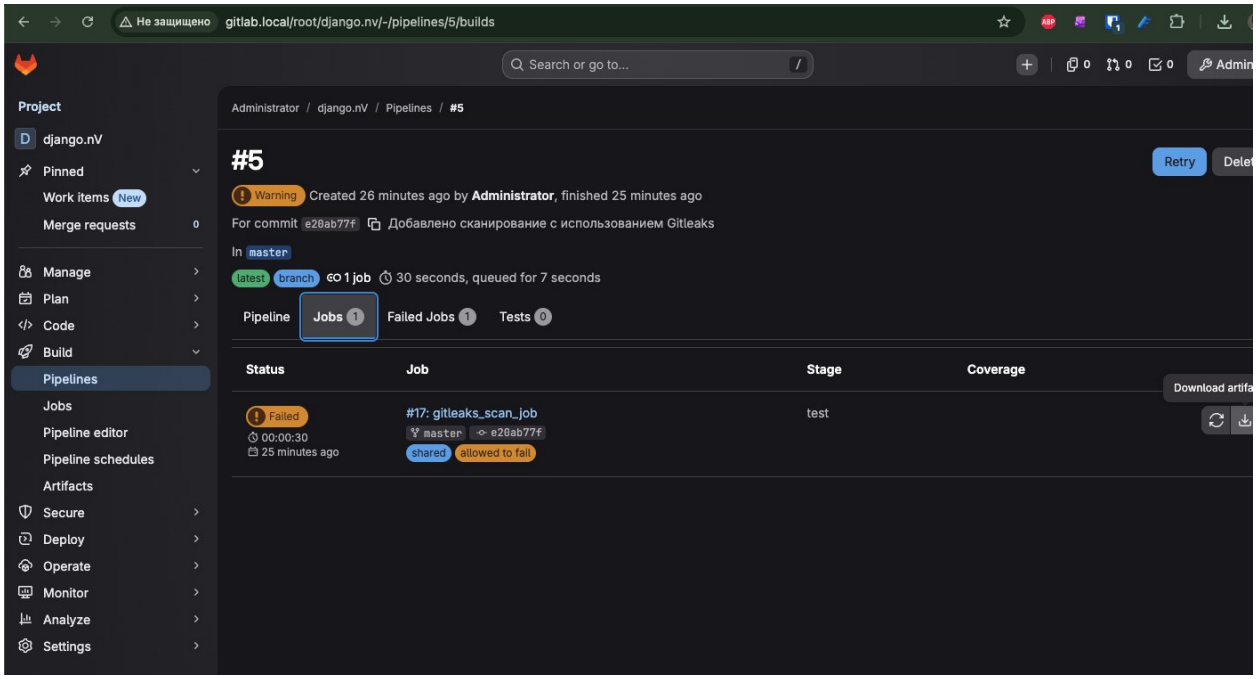
На хостовой машине запустить следующие команды:

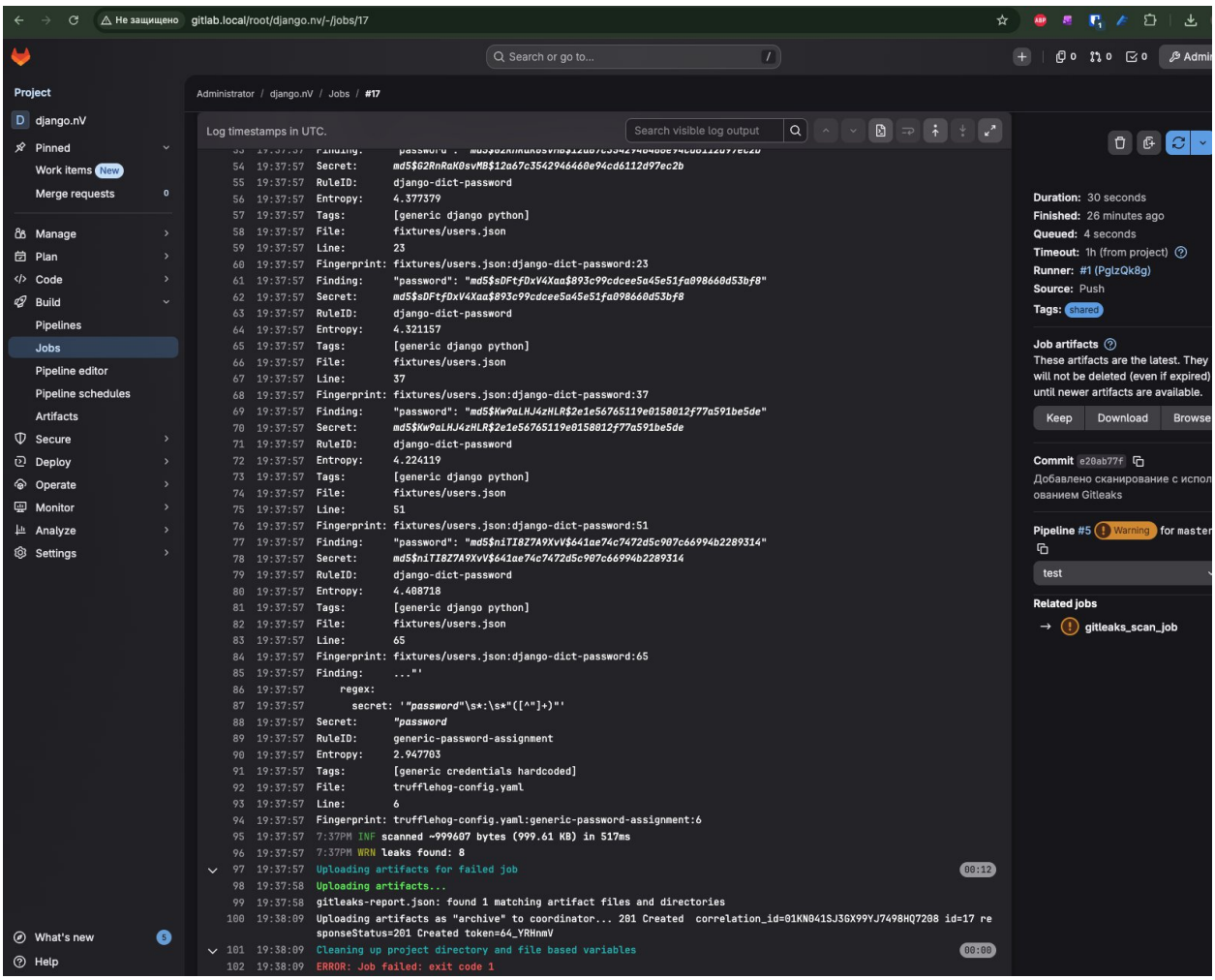
```bash
git remote remove origin
git remote add origin http://gitlab.local/root/django.nv.git
git add .
git commit -m "Add Gitleaks security scanner to CI/CD"
git push -u origin master
```



После пуша запустится джоба с проверкой секретов.

В результате выполнения получаем Артефакт и так же вывод в консоль





Все коммиты можно найти в личном пространстве

https://github.com/sapsolman/netology-hse